Федеральное государственное автономное образовательное учреждение высшего образования «Национальный исследовательский университет ИТМО»

Факультет программной инженерии и компьютерной техники

Дисциплина
«Информационная безопасность»

Лабораторная работа №4

Анализ уязвимостей веб-приложения с помощью OWASP ZAP

Выполнил: Малышев Никита Александрович
Группа: P3412
Проверила: Маркина Татьяна Анатольевна

Санкт-Петербург
2026 год

Содержание

1. Выполнение 3
    1.1. Межсайтовый скриптинг (Cross Site Scripting) 3
    1.2. Внешнее перенаправление (External Redirect) 4
    1.3. Обход каталогов (Path Traversal) 5
2. Вывод 6

1. Выполнение

Сканирование было выполнено с помощью встроенного функционала OWASP ZAP. Был запущен режим «Quick Scan» для целевого URL http://testasp.vulnweb.com/. Инструмент автоматически выполнил разведку (spidering) сайта, обнаружил его структуру и провел активное сканирование на наличие распространенных уязвимостей. В результате был сгенерирован подробный отчет, содержащий 18 типов найденных проблем, сгруппированных по уровню риска: 5 критических (High), 4 средних (Medium), 7 низких (Low) и 2 информационных (Informational), как показано на Рис. 1.

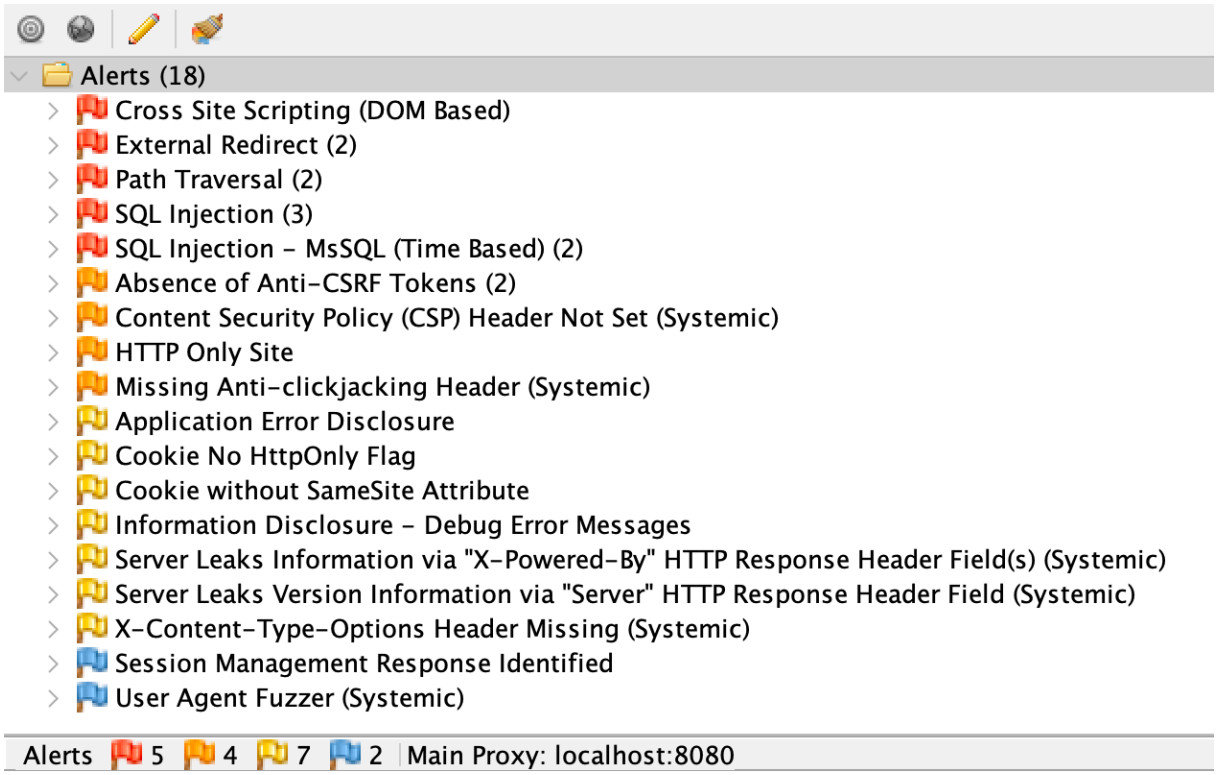


Рис. 1. Предупреждения ZAP

Ниже представлены три наиболее критичных типа уязвимостей, обнаруженных в ходе сканирования, с описанием их сути и потенциального воздействия.

1.1. Межсайтовый скриптинг (Cross Site Scripting)

Уровень риска: Высокий (High), **количество экземпляров:** 1.

Это тип атаки, при котором вредоносный скрипт внедряется и выполняется в браузере жертвы, используя объектную модель документа (DOM) или полученные из HTTP-запроса данные. Уязвимость возникает из-за того, как клиентский JavaScript обрабатывает данные из источников, кон-

тролируемых злоумышленником (например, параметры URL или поля формы). В отчете показано, что ZAP успешно внедрил полезную нагрузку `<script>alert(5397)</script>` в параметр `tfSearch` страницы `Search.asp` (метод GET), что привело к выполнению произвольного JavaScript-кода в браузере и подтверждает наличие уязвимости, как показано на Рис. 2.

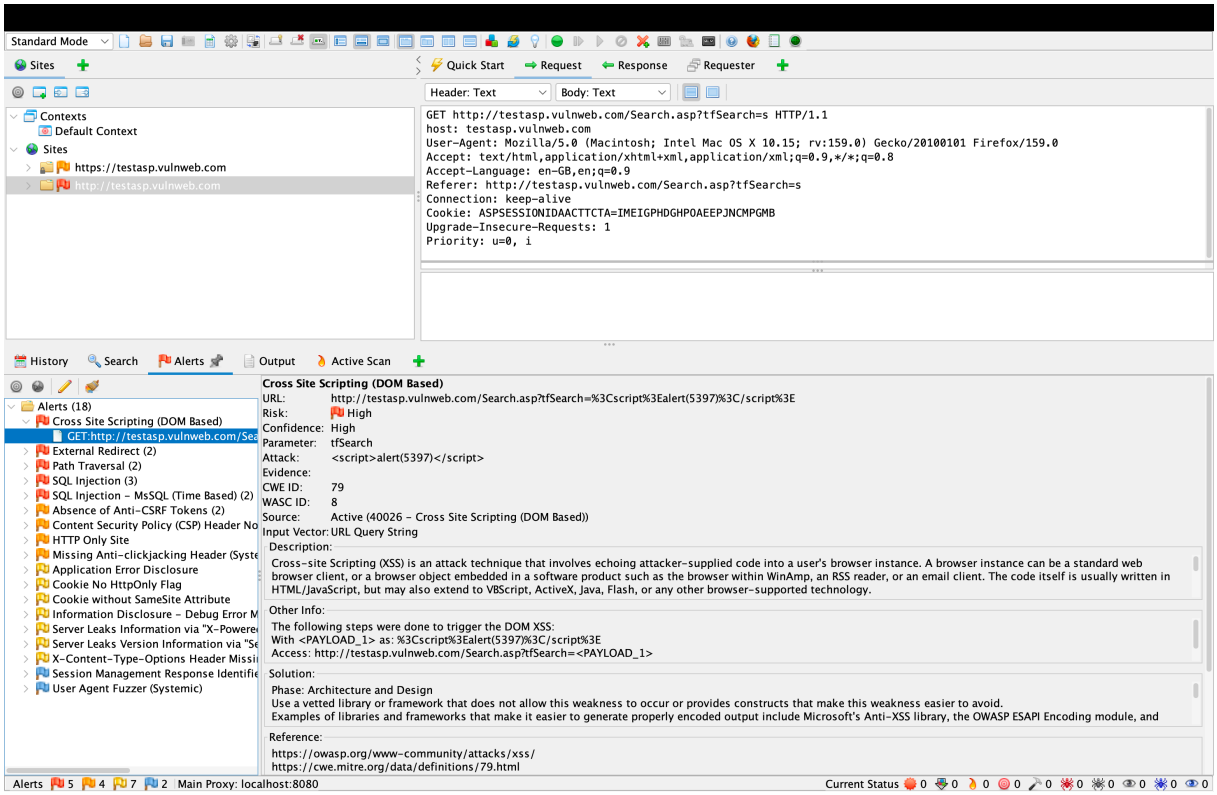


Рис. 2. Найденная ZAP уязвимость Cross Site Scripting, DOM Based

Так, злоумышленник может украсть сессионные куки пользователя, перенаправить его на фишинговый сайт или выполнить любые действия от его имени в рамках текущей сессии.

1.2. Внешнее перенаправление (External Redirect)

Уровень риска: Высокий (High), **количество экземпляров:** 2.

Уязвимость возникает, когда приложение принимает от пользователя адрес для перенаправления и подставляет его в заголовок `Location` ответа без проверки. ZAP подставил в параметр `RetURL` внешний адрес `https://710625619493630640.owasp.org` в запросах к `Logout.asp` (метод GET) и `Login.asp` (метод POST), и сервер вернул перенаправление на этот адрес. Это подтверждается значением в поле Evidence и пояснением «ответ содержит перенаправление в заголовке `Location`, позволяющее задать внешний URL», как показано на Рис. 3.

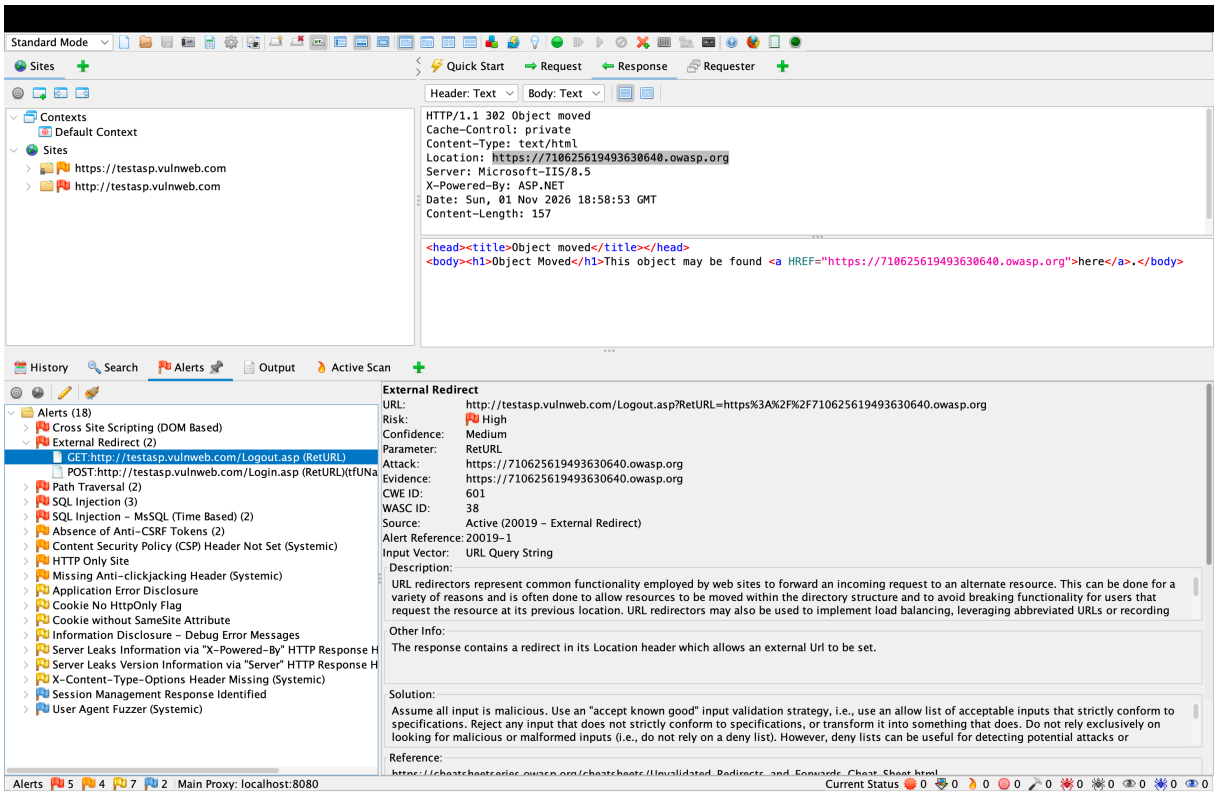


Рис. 3. Найденная ZAP уязвимость External Redirect

Злоумышленник может отправить жертве ссылку на легитимный домен `testasp.vulnweb.com` с вредоносным значением `RetURL`: после выхода из системы или входа в неё пользователь будет автоматически перенаправлен на фишинговый сайт, который выглядит доверенным. Это позволяет похищать учетные данные и распространять вредоносное ПО.

1.3. Обход каталогов (Path Traversal)

Уровень риска: Высокий (High), **количество экземпляров:** 2.

Атака позволяет получить доступ к файлам и каталогам, расположенным за пределами корневого каталога веб-сервера. Она возможна, когда приложение использует пользовательский ввод при формировании пути к файлу без должной проверки. ZAP подставил в параметр `item` страницы `Templatize.asp` последовательность `../../../../../../../../../../../../../../../Windows/system.ini`, и в ответе сервера было обнаружено содержимое системного файла Windows (признак — строка `[drivers]`), что подтверждает чтение произвольных файлов, как показано на Рис. 4. Второй экземпляр относится к параметру `tfUName` формы регистрации `Register.asp`.

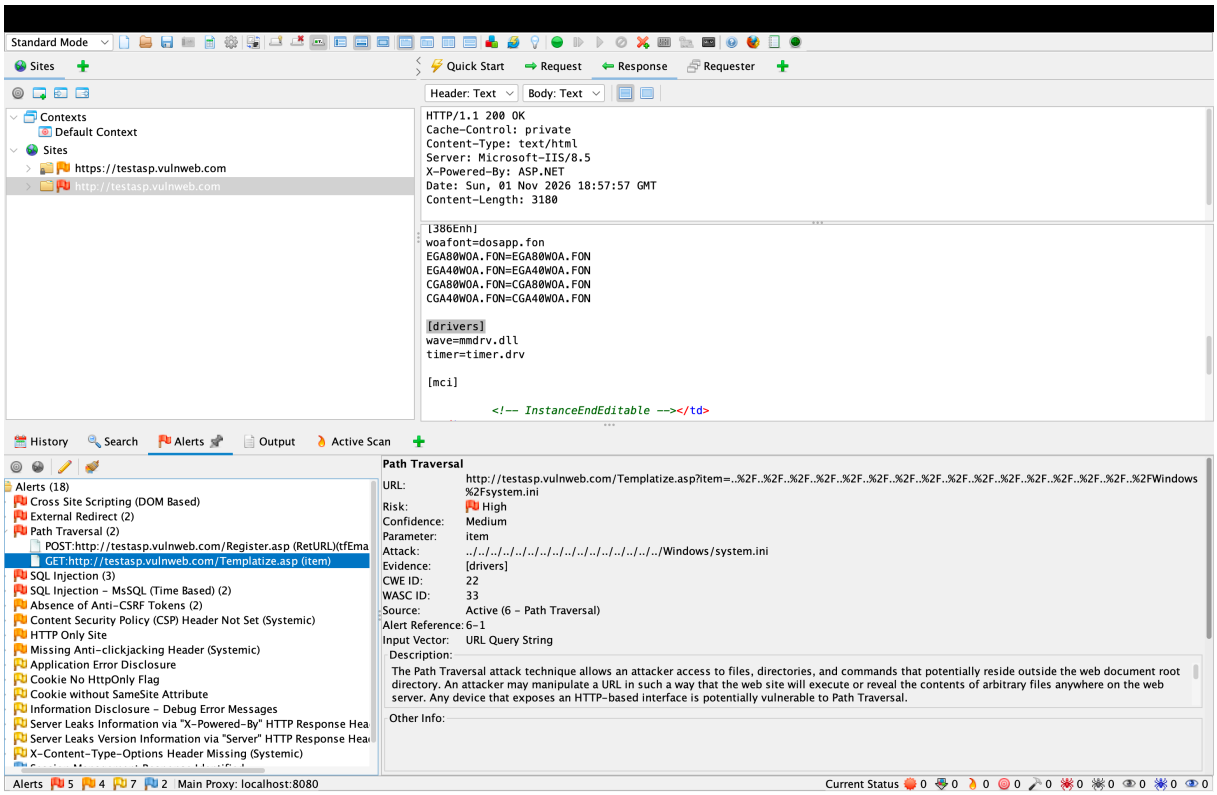


Рис. 4. Найденная ZAP уязвимость Path Traversal

Злоумышленник может прочитать конфиденциальные файлы сервера: конфигурации, исходный код приложения, файлы с паролями и строками подключения к базе данных. Полученные сведения затем могут быть использованы для развития атаки.

2. Вывод

Все проблемы возникают по одной причине: сайт верит всему, что присылает пользователь, и не проверяет это. Из-за этого в страницу можно подсунуть чужой скрипт, увести человека по ссылке на фишинговый сайт или прочитать файлы прямо с сервера. Чтобы это исправить, нужно проверять ввод по белому списку, экранировать вывод на страницу и не пускать пути и адреса, которых не ожидаешь. В реальном проекте так оставлять нельзя.